Firestore rules tests (EPIC-017/T2 S2, #155)

Evidence status: not yet committed. The emulator-based suite below is written and ready (rules-tests/), but it could not be run to completion on the machine this PR was built on — see "Known issue in this environment". AC #155 ("the evidence is committed") is open until the suite is run successfully once, here or on a teammate's machine, and its output or a screenshot is committed to this file.

Setup

```
cd rules-tests
npm install
npm run test:rules
```

test:rules runs firebase emulators:exec --only firestore "node --test rules-tests/test/*.test.js" from the repo root, so it needs firebase.json (emulator port) and firestore.rules from there. No Firebase login is required — the emulator runs entirely offline.

What it covers

rules-tests/test/rules.test.js, using @firebase/rules-unit-testing against the local emulator. Every "valid write" fixture (rules-tests/test/fixtures.js) mirrors the app's DTO toMap() output exactly (explicit nulls for unset optionals, serverTimestamp() for createdAt/updatedAt), so a rule that only passes on a hand-trimmed payload would still let a real client write fail silently.

#	Case	Expected
1	Owner reads their own profile	allow
2	A different signed-in user reads the profile	deny
3	Unauthenticated request reads the profile	deny
4	Valid profile create	allow
5	Valid account create	allow
6	Valid category create	allow
7	Valid expense transaction create (explicit-null optionals)	allow
8	Valid transfer transaction create	allow
9	Valid invoice create	allow
10	Valid recurring create	allow
11	Valid goal create	allow
12	Unknown field on create	deny
13	Negative amount on a non-crypto expense	deny
14	Crypto realised loss (negative amountLkrMinor)	allow
15	Transfer to the same account (toAccountId == accountId)	deny
16	Expense without a category	deny

#	Case	Expected
17	Recurring dayOfMonth 31	deny
18	Profile with incomeEstimateMinMinor > max	deny
19	Hard delete (any collection)	deny
20	Soft delete (deletedAt update only)	allow
21	Changing createdAt on update	deny
22	Settling a PENDING invoice (status → RECEIVED)	allow
23	Settling an already-RECEIVED invoice a second time	deny
24	Reverting a RECEIVED invoice back to PENDING	deny
25	Soft-deleting a RECEIVED invoice (deletedAt update only)	allow

This is a superset of the AC's 12 named cases (owner read, other-user deny, unauthenticated deny, one valid write per collection, unknown field deny, negative non-crypto amount deny, crypto loss allow, same-account transfer deny, category-less expense deny, dayOfMonth 31 deny) plus mutation cases the DTO shapes make worth locking down (hard delete, soft delete, createdAt immutability, the invoice double-settle guard added alongside the rewrite — see firestore.rules). Cases 22–25 cover a CodeRabbit finding on the first draft of that guard: it blocked *any* edit to a settled invoice (soft delete included) while still letting RECEIVED revert to PENDING — fixed by gating on the **stored** status (resource.data.status) rather than denying on both-sides-RECEIVED.

Known issue in this environment

On the Windows machine this PR was authored on, the Firestore emulator (v1.22.0) starts and accepts plain HTTP (curl/fetch against it respond in milliseconds), but every Firestore JS SDK call (firebase 11.10.0, modular or compat, gRPC or experimentalForceLongPolling) times out after 10s with "Could not reach Cloud Firestore backend", and the emulator's own firestore-debug.log never shows the request arriving. A low-level trace shows the HTTP/2 session to the emulator completing its handshake, then no further frames in either direction — consistent with something on this machine (antivirus/firewall HTTP/2 payload inspection is the leading suspect) silently dropping the Watch-stream traffic the SDK uses, while leaving plain HTTP alone. Ruled out: proxy env vars (none set), the gRPC DNS resolver (GRPC_DNS_RESOLVER=native made no difference), and sandboxed vs. unsandboxed execution (both hang identically).

Next step: run npm run test:rules on a different machine (or this one with the interfering software identified/disabled) and commit the passing output here, replacing this section.

Fallback (if the emulator still can't run before this PR needs to ship)

Firebase Console → Firestore Database → Rules → **Rules Playground**, run each case in the table above by hand (auth: Simulation type get/create/update/delete, location /databases/(default)/documents/users/{uid}/..., "Authenticated" with a matching/mismatched UID), screenshot the Allow/Deny result, and commit the screenshots under Docs/testing/rules/.